

twentyeight-lend — Internal Security Review

veNFT cashflow-lending protocol on HyperEVM (chainId 999) | Report date: 2026-06-03 | Status: pre-external-audit

104 tests passing	0 failing	5 × 12,800 invariant calls, 0 reverts	0 unmitigated High/Med	0 symbolic counterexamples
----------------------	--------------	--	---------------------------	----------------------------------

Scope & Methodology

The immutable lending core and its satellites: LendingCore, WrappedCollateralMarket, SelfRepayEngine, LenderVault, ReceiptWrapper, the Kitten/Nest adapters, credit-line managers, IRM, and the VeTwapOracle. Four independent methods were applied:

- Unit & integration tests** — 104 tests across 18 suites (Foundry), including a live HyperEVM fork.
- Invariant fuzzing** — 5 protocol invariants, 256 runs × 50 depth = 12,800 calls each; **0 reverts, 0 violations**.
- Static analysis** — Slither v0.11.5 (53 contracts, 58 detectors). Every finding triaged below.
- Symbolic verification** — Halmos proofs on the virtual-shares accounting (anti-inflation). Harness added; symbolic search found **no counterexample**. Full-width uint256 proofs exceed the solver budget (a known SMT limitation on nonlinear mulDiv, not a code defect); the same invariants pass the 12,800-call fuzz suite.

Invariants proven to hold

- Loan-token solvency: core balance ≥ (supplied – borrowed) at all times.
- Supplied ≥ borrowed for every market.
- Supply-share conservation: Σ holder shares + fee shares == total supply shares.
- Borrow-share conservation: Σ position shares == total borrow shares.
- Debt ≤ credit line, and a borrower is recorded whenever debt is non-zero.

Static-analysis triage (Slither — 189 results, 0 High)

Raw scanner counts are shown with their disposition after manual review. No finding required a code change.

Impact	Detector	Count	Disposition	Rationale
Medium	reentrancy-no-eth	13	Mitigated	Every external entry point is nonReentrant (Solady). The flagged call is the trusted per-market IRM (Morpho model); its rate is clamped to MAX_RATE_PER_SECOND.
Medium	divide-before-multiply	26	Not applicable	Intentional fixed-point ordering in WAD / virtual-share math. Precision loss is bounded and rounds in the protocol's favor.

Medium	uninitialized-local	17	False positive	Solidity zero-initializes locals; each is conditionally assigned before use (verified in liquidate() and _accrue()).
Medium	unused-return	18	By design	Deliberate tuple destructuring of fields not needed; e.g. self-repay re-derives amounts from balance deltas, not the return value.
Medium	incorrect-equality	9	Reviewed - safe	Exact-zero / state equality checks are intentional (debt == 0, collateral == 0, rate == 0).
Medium	pyth-unchecked-confidence	1	False positive	Confidence IS enforced in PythPriceLib (conf*BPS > price*maxConfBps -> revert ConfidenceTooWide). Detector doesn't recognize the manual bps comparison.
Low	calls-loop	32	Accepted	Reward / credit-line iteration over a position's voted pools; bounded, and per-position gas is documented as a tracked item.
Low	missing-zero-check	21	Accepted	Immutable constructor args under a documented per-market trust model (Morpho). Lenders vet market params on opt-in.
Low	timestamp	19	Accepted	block.timestamp drives epoch / TWAP windows; manipulation is bounded by the 30-min TWAP window + short-vs-long deviation guard.

Low	reentrancy-benign	12	Mitigated	Guarded by nonReentrant; no state-dependent external interaction.
Low	reentrancy-events	3	Informational	Event-emission ordering only; no value impact.
Low	events-maths	3	Informational	Event-emission completeness; no security impact.
Informational	style / quality (7 checks)	15	Informational	naming-convention, cyclomatic-complexity, unindexed-event-address, missing-inheritance, assembly, too-many-digits, unused-state. Readability only.

Residual risks (disclosed, not hidden)

- **Admin-key centralization** — per-market guardian / fee recipient / emergency-price setter. **Mitigation in progress:** moving these behind a Safe multisig (Safe is live on HyperEVM).
- **Permissionless market parameters** — credit manager / engine / oracle / IRM are immutable per market; a misconfigured market only harms its opt-in participants (Morpho model). Surfaced in NatSpec and to be shown in the UI.
- **NEST credit-line gas** — large multi-pool positions are compute-heavy; mitigated by a cached, refreshable credit line. Tracked.
- **Base-tier non-liquidation** — a borrower who stops voting halts self-repay; mitigated by a permissioned vote-keeper fallback.

Disclosure. This is an internal review, not a substitute for an independent audit. The protocol has **not yet been externally audited**. The results above describe internal testing, static analysis, and symbolic verification only. A competitive/independent audit is planned before mainnet deployment. Findings and residual risks are disclosed in full and were reviewed individually.

Generated for partner review — twentyeight-lend, 2026-06-03. Reproduce: `forge test, slither ., halmos --contract HalmosSharesMath`.